

# FARI

## Framework Specification

### Framework for Aerospace Research and Investigation v1.2.0

Canonical specification, glossary, workflow, companion profile, and release guidance

FARI v1.2.0 | 2026-06-26

This is the versioned release edition of the FARI documentation bundle. Canonical working sources for this release are stored under the same version folder.

## Canonical specification for FARI v1.2.0

### Purpose

FARI is the executive and traceability layer for aerospace security research. It does not replace the technical method used by an auditor. Instead, it gives the report author one consistent way to frame the scope, normalize evidence, connect findings to mission meaning, and conclude each investigation in a way that can be read quickly by technical and executive audiences.

The design goal is simple:

- let the attacker or external auditor work in their own format;
- keep the extra reporting burden on the FARI report author, not on the evidence producer;
- preserve uncertainty instead of hiding it;
- produce one investigation report per claim and one consolidated report for the whole assessment.

### Core principles

1. **Method agnostic.** Firmware review, RF testing, FlatSat validation, cloud review, reverse engineering, and emulation can all feed the same framework.
2. **Evidence before interpretation.** Facts, assertions, inferences, assumptions, contradictions, and gaps are different things and must stay separated.
3. **Mission-aware conclusions.** A lab exploit and an on-orbit mission effect are not the same conclusion.
4. **No hidden score.** FARI does not depend on CVE, CVSS, CWE, or a numeric average. It uses qualitative decisions that can still be aggregated.
5. **External-auditor friendly.** An external tester does not need to know FARI and should not be forced to complete a FARI form.
6. **Closed means immutable.** Once an investigation or assessment is closed, it becomes a final record. New work should create a new revision or follow-on assessment.

### Roles

#### Technical reporter

The technical reporter is the person or team that produced the evidence. This can be an internal researcher, external red team, lab engineer, hardware analyst, RF specialist, or software auditor.

The technical reporter is responsible for the technical work and the fidelity of their evidence, but not for FARI normalization or executive framing.

#### Report author

The report author transforms supplied material into FARI records. In the web application this role is currently fixed as *Fari-Agent*.

The report author is responsible for:

- defining the Frame;

- translating raw material into normalized sections;
- deciding sufficiency and conclusion states;
- relating findings to SPARTA and other references;
- generating investigation and consolidated reports.

## **Client or mission owner**

The client or mission owner provides the business and mission context that makes the conclusions meaningful. They are also the consumer of the final result.

## **Lifecycle**

FARI has four phases:

1. **Frame**
2. **Acquire**
3. **Relate**
4. **Inform**

The web workflow and the manual template use the same sequence.

In the current web workspace, those phases are also presented as a horizontal workflow timeline directly under the page hero so the report author can see the current state without losing screen space to a permanent side rail.

## **Traceability and revisions**

FARI assessments can evolve as evidence is added, findings are normalized, SBOM inventory changes, and closure reviews happen. For that reason, FARI supports explicit assessment revisions.

### **What a revision is**

A revision is a captured snapshot of the assessment state at a meaningful moment. It is not the same thing as every keystroke or every save.

Typical revision points:

- after a major evidence intake;
- after findings and SPARTA mappings are normalized;
- after a meaningful SBOM refresh;
- before executive review;
- automatically when the assessment is closed.

### **Why revisions matter**

Revisions answer questions such as:

- what changed between the draft and the final assessment;
- when a claim conclusion changed;

- when an SBOM import changed a recorded component version;
- whether a final report corresponds to a known assessment state.

## Revision rules

- The assessment identifier remains stable.
- The revision label changes, for example v1, v2, v3.
- A closed assessment should always have a final captured revision.
- A revision stores structure and traceability, not just a static rendered report file.

## Difference review

FARI should be able to compare one revision against another revision or against the current working state. At minimum, the comparison should show changes in:

- assessment fields;
- assets;
- investigations and conclusions;
- Attack Flow references;
- SBOM documents;
- inventory components and their tracked status.

## Frame

The Frame defines what is being evaluated and under which limits. If the Frame is vague, the rest of the report becomes hard to defend.

## Fields in the Frame

### Client name

The organization or mission owner that requested the work.

Fill it with the exact name that should appear in the report.

### Assessment title

A short label for the engagement. It should identify the system, campaign, or focus area, for example SpaceCAN Replay Resistance Review.

### Mission context

A concise explanation of where this assessment matters. This should describe the system role, environment, mission stage, or operational importance.

Good example:

Lab validation of the telemetry monitoring path for a representative spacecraft bus interface before integrated vehicle testing.

## Scope

The technical boundary of the work. This is one of the most important fields in FARI because it defines what the conclusions actually mean.

Include:

- in-scope assets;
- environments;
- interfaces;
- data paths;
- known limits of access.

Avoid broad claims such as `entire spacecraft security`.

## Authorization

What permission made the work legitimate. If special handling, RF windows, or test approvals were required, state them here.

## Exclusions

Anything explicitly out of scope. This protects the report from being read as a claim about systems that were never tested.

## Assets

Each asset should be specific enough to be referenced by evidence and findings.

At minimum, each asset should have:

- name;
- segment;
- access basis;
- coverage state;
- short description.

Recommended segment values are:

- `space`
- `ground`
- `link`
- `user`
- `supply_chain`
- `cloud`
- `other`

Use the segment that best describes where the assessed exposure primarily exists. For example, a mission API gateway or hosted processing backend should normally be recorded as `cloud`, even if it

supports a space or ground mission function.

Use **other** when the asset is an intentional combination of segments or does not fit the predefined set cleanly.

Recommended access values are:

- **public**
- **private**
- **other**

Use **public** when the material or exposure was obtainable through internet reachability, OSINT, partner-visible interfaces, third-party disclosures, or other non-restricted sources.

Use **private** when the material or exposure required authorized internal access, lab access, source access, customer-provided credentials, or restricted mission documentation.

Use **other** when the access path is mixed, inherited from several parties, or does not fit cleanly into a public/private distinction.

## Claim description

The claim is the expected secure behavior being tested. It should be testable, not aspirational.

Good claim:

The monitor distinguishes forged reply-like frames before presenting them as trusted state.

Weak claim:

The system is secure against spoofing.

The claim should be narrow enough that **Meets**, **Does Not Meet**, or **Inconclusive** mean something precise.

## Acquire

Acquire is where raw material becomes normalized assessment content. This is the phase that most clearly separates the external auditor from the report author.

The external auditor can deliver screenshots, packet captures, notes, logs, scripts, lab observations, or a finished technical report. The report author is the one who transforms that material into FARI language.

## Evidence

Evidence files are the preserved artifacts. Each one should have a short description and remain attached to the related investigation.

Examples:

- packet capture;
- screenshot;

- tool output;
- script;
- attack flow;
- document from an external auditor.

## SBOM inventory

FARI treats SBOM and dependency inventories as first-class supplied material. They are especially useful for software-heavy spacecraft, payload, ground systems, mission applications, and supplier-delivered binaries.

An SBOM upload should create two related records:

- an **SBOM document** that preserves the supplied source file;
- an **inventory component** record for each tracked dependency or package.

This lets the report author answer both:

- what file was supplied; and
- what component state FARI currently believes is true.

## Inventory component timeline

Each component can accumulate events over time, for example:

- imported from SBOM;
- vulnerability detected;
- version updated;
- status changed;
- fix verified;
- analyst note.

This timeline is what allows FARI to say:

- which version was present when the vulnerability was observed;
- when the version changed;
- whether the fix was only applied or also verified.

## Facts

Facts are statements directly supported by evidence.

Good fact:

A forged frame was transmitted onto the local bus.

Not a fact unless directly shown:

The flight computer trusted the forged command.

## Assertions

Assertions are statements supplied by the technical reporter that are useful but not independently demonstrated by the report author.

Example:

The bytes 01 FF represent a valid thruster-state response for node 0x04.

## Inferences

Inferences are report-author interpretations derived from the evidence and context.

Example:

The display can be influenced by attacker-controlled traffic in the tested environment.

## Assumptions

Assumptions are conditions treated as true for the purpose of the analysis even though they are not demonstrated by current evidence.

Example:

Operators may use the displayed values for operational decisions.

## Contradictions

Contradictions record conflicts that matter to the conclusion. They should not be hidden inside the narrative.

Example:

The screenshot suggests a changed value, but the provided notes do not state whether the field is decoded or raw.

## Gaps

Gaps are the missing information that prevents a stronger conclusion.

Examples:

- no proof of production deployment path;
- no configuration confirming freshness validation;
- no evidence of physical actuator effect.



## Sufficiency fields

FARI uses three sufficiency decisions:

### Technical sufficiency

Whether the evidence is enough to conclude the technical condition under test.

- **Sufficient**: enough to conclude the technical behavior.
- **Partial**: enough for part of the behavior, but not all of it.
- **Insufficient**: not enough to conclude the condition.

### Reachability sufficiency

Whether the path to exploitation or exposure is supported within the current scope.

This is what prevents a lab-only result from silently becoming an operational reachability claim.

### Mission sufficiency

Whether the consequence to mission or operations is directly shown, partially supported, or still speculative.

## Relate

Relate turns normalized material into findings, scenarios, and framework references.

## Findings

A finding is the reportable condition that came out of the investigation. The finding can be broader or narrower than a single evidence file, but it should still map cleanly to the claim being evaluated.

Each finding should contain:

- a concise title;
- state;
- condition text;
- observed effect;
- credible impact;
- optional SPARTA mapping and rationale.

## SPARTA

SPARTA is a key reference inside FARI for spacecraft-relevant tactics, techniques, and countermeasures.

FARI uses SPARTA to describe behavior and recommended countermeasures, but SPARTA does not decide the FARI conclusion automatically.

Use SPARTA when it improves clarity. Do not force a weak mapping only because the wording feels similar.

## Attack flow diagrams

Attack Flow Builder files and SPARTA-oriented diagrams support the narrative by showing sequences, dependencies, and grouped actions. They are reference artifacts and should remain read-only evidence aids inside the application.

## Relationship between findings and inventory

SBOM inventory does not replace a finding.

Use the inventory when tracking package/component state over time. Use a finding when there is a reportable condition that contributes to a claim conclusion.

Example:

- inventory event: `openssl` moved from `3.0.9` to `3.0.14`;
- finding: vulnerable dependency handling permits deployment of a version with a known exploitable weakness.

## Inform

Inform is where the report author decides what the investigation means and what the client should do next.

## Conclusion

The FARI conclusion is about whether the claim was satisfied within the stated scope.

Allowed values:

- `Meets`
- `Does Not Meet`
- `Inconclusive`
- `Not Assessed`

## How to choose the conclusion

Use `Meets` when the available evidence supports that the expected behavior holds within the declared boundary.

Use `Does Not Meet` when the available evidence supports that the expected behavior failed within the declared boundary.

Use `Inconclusive` when the current evidence cannot resolve the claim and more work is needed.

Use `Not Assessed` when the claim has not truly been evaluated yet.

## Scenario disposition

Scenario disposition is separate from the claim conclusion. It describes the broader attack path or risk story.

Allowed values:

- `Demonstrated`
- `Plausible`

- Not Demonstrated
- Not Evaluated

This distinction is important. A claim can conclude **Does Not Meet** for a lab monitoring path while the broader attack scenario remains only **Plausible** because operational reachability or mission consequence is not yet proven.

## Confidence

Confidence expresses how strong the report author believes the current evidence base is.

- High
- Medium
- Low

## Required action

Required action is the executive next step.

Allowed values:

- Accept
- Remediate
- Extend Investigation
- Retest
- No Action

Recommended interpretation:

- **Accept** when the claim is satisfied and there is no corrective work.
- **Remediate** when a corrective action is needed.
- **Extend Investigation** when scope or evidence must grow before closing the question.
- **Retest** when a condition or fix must be validated again.
- **No Action** when there is nothing meaningful to do from the current result.

## Priority

Priority is a simple qualitative ordering for action:

- Immediate
- Planned
- Routine
- None

## Scope boundary

This field explains exactly where the conclusion applies. It should be written as a sentence, not just a label.

Good example:

Conclusion applies to supplied lab replay and spoofing evidence affecting the SpaceCAN monitor path only; physical response, production controls, and on-orbit behavior were not assessed.

## **Rationale**

The rationale is the shortest defensible explanation of why the selected conclusion is correct.

## **Recommendations**

Recommendations describe what should happen next in engineering or assessment terms.

## **Acceptance criteria**

Acceptance criteria define what evidence would allow the issue to close or the claim to be revalidated.

## **Closure rules**

An investigation should close only when it has:

- a clear claim;
- evidence or normalized supplied material;
- a selected scenario disposition;
- a valid conclusion and required action combination;
- rationale and scope boundary;
- enough context that a reader can understand the decision without reopening the raw evidence set immediately.

An assessment should close only when:

- its scope is defined;
- assets are registered;
- at least one gating investigation exists;
- all gating investigations are closed.

## **Consolidated reporting**

FARI does not stop at individual investigations. It also produces one final assessment-level view.

The consolidated report should:

- identify the client and scope;
- summarize assets;
- list all investigations;
- totalize conclusions and scenario dispositions;
- show required actions;

- provide one overall conclusion for the assessment.

The overall conclusion is derived from gating investigations:

1. if any gating investigation is **Does Not Meet**, the assessment is **Does Not Meet**;
2. otherwise, if any gating investigation is **Inconclusive** or **Not Assessed**, the assessment is **Inconclusive**;
3. otherwise, it is **Meets**.

This preserves clarity without creating a misleading average score.

## Compliance scenarios and companion profiles

FARI is not a certification scheme and should not pretend to be one.

What FARI does well is preserve the evidence, claim logic, scope boundaries, findings, SPARTA relationships, and executive decisions that a compliance conversation needs in order to stay honest.

When a mission owner also wants a recognizable control-oriented view, FARI should use a **companion profile** instead of bending the core framework away from its purpose.

## How FARI can support compliance decisions

The same assessment can move through different compliance proceeding scenarios. These are not numeric scores. They are qualitative operating modes for the report author and client.

1. **Evidence-backed alignment** The relevant controls are implemented and directly supported by FARI evidence, claims, and findings.
2. **Partial alignment** Some controls are implemented while others are only partially implemented or planned, but the assessment is still usable because the gaps are explicit.
3. **Compensating controls** A direct control may be absent, but alternative safeguards reduce the same mission exposure and are documented with rationale.
4. **Inconclusive due to scope boundary** The assessment cannot support a clean compliance statement because access, environment, supplier visibility, or mission consequence evidence is limited.
5. **Supplier attestation pending** Compliance depends on third-party firmware, hosted services, or external operational controls that still require validation or vendor evidence.
6. **Continuous assurance** The assessment is treated as a living baseline and updated through retest, SBOM refresh, monitoring changes, and new revisions.

## Companion profile model

The recommended pattern is to keep FARI as the claim-and-evidence layer and add one or more external profiles that reference FARI records.

For example:

- FARI investigation INV-0001-001
- evidence EVD-0001-003
- Attack Flow AFB-0001-001

- SBOM document SBM-0001-001
- component CMP-0001-004

Those records can then be cited by a companion control such as:

Replay protection exists on the command path.

This preserves one important boundary:

- FARI decides whether the tested claim was supported.
- the companion profile decides how that evidence maps to a control view.

### SPD-5 companion profile

The first recommended companion is an SPD-5-inspired checklist based on the official *Space Policy Directive-5: Cybersecurity Principles for Space Systems* guidance published by the U.S. Government.

Reference:

- Space Policy Directive-5 official PDF (<https://www.transportation.gov/sites/dot.gov/files/2023-11/Memorandum%20on%20Space%20Policy%20Directive-5%E2%80%94Cybersecurity%20Principles%20for%20Space%20Systems.pdf>)

The companion profile groups controls into these families:

- Governance
- Ground Segment
- Space Segment
- Communications
- Supply Chain
- Monitoring

Each control should be assigned one qualitative implementation state:

- Implemented
- Partially Implemented
- Planned
- Not Implemented
- Not Applicable
- Not Verified

The profile itself can then roll up into one qualitative posture:

- Aligned
- Partially Aligned
- Gap Identified
- Inconclusive

- Not Started

These postures are not legal determinations and not replacements for authority review. They are internal executive signals that help the client understand how far the available evidence currently supports an SPD-5-style control statement.

## Relationship to closure

Companion profiles should normally remain **outside the minimum closure gates** for a FARI investigation or assessment.

Reason:

- a FARI assessment may still be complete and useful even when a compliance overlay is not yet filled;
- a companion profile may depend on governance evidence, supplier attestations, or operational decisions that were never part of the original technical scope.

In practice:

- close the FARI record when the claim-based investigation is complete;
- continue or reopen work in a new revision when the compliance overlay gains better evidence or a different conclusion.

## Traceable inventory example

Assume an SBOM import registers:

- component `libfoo`
- current version `1.4.2`
- status `Tracked`

Later, a reviewer records:

- event type: `Vulnerability Detected`
- vulnerability ID: `CVE-2026-0001`
- status after: `Vulnerable`

After engineering updates the package:

- event type: `Version Updated`
- from version: `1.4.2`
- to version: `1.4.5`
- status after: `Update In Progress`

After retest:

- event type: `Fix Verified`
- to version: `1.4.5`
- status after: `Fixed`

This is different from a normal finding because the timeline is centered on the component lifecycle, not only on one investigation claim.

## Simple worked example

This example shows how a small manual assessment should be filled.

### Scenario

A lab monitor receives SpaceCAN traffic. The supplied evidence shows that a forged frame changes the displayed value.

### Frame entries

- Client name: Example Aerospace
- Assessment title: SpaceCAN Monitor Validation
- Mission context: Lab validation before integrated system testing
- Scope: SpaceCAN monitor display path in representative lab bus
- Exclusions: No physical actuator validation and no on-orbit behavior
- Claim: The monitor distinguishes forged reply-like frames before presenting trusted state

### Acquire entries

- Facts:
  - Forged traffic was transmitted
  - The displayed value changed from 12 to 255
- Assertions:
  - The message bytes represent a reply-like telemetry field
- Inferences:
  - The display can be influenced by attacker-controlled traffic in the tested path
- Gaps:
  - No proof of operational reachability
  - No proof of physical effect
  - Technical sufficiency: Sufficient
  - Reachability sufficiency: Partial
  - Mission sufficiency: Partial

### Relate entries

- Finding title: Forged reply-like frame influences displayed telemetry
- SPARTA mapping: EX-0014.02 Bus Traffic Spoofing



- Mapping state: Confirmed

## Inform entries

- Conclusion: Does Not Meet
- Scenario disposition: Plausible
- Confidence: Medium
- Required action: Remediate
- Priority: Immediate
- Scope boundary: Lab monitor path only
- Rationale: The tested display accepted attacker-controlled traffic as trusted state

This is a good example of a report that is conclusive for the claim but still careful about the broader attack path.

## Manual filling sequence

When filling FARI by hand, use this order:

1. define the Frame;
2. attach or register the supplied material;
3. separate facts, assertions, inferences, assumptions, contradictions, and gaps;
4. decide the three sufficiency fields;
5. normalize findings and SPARTA mappings;
6. choose conclusion, scenario disposition, confidence, action, and priority;
7. if software inventory matters, ingest SBOM material and update component timelines;
8. capture a revision whenever the assessment meaning changed materially;
9. write scope boundary, rationale, recommendations, and acceptance criteria;
10. close the investigation only when the record can stand on its own.

## Glossary

### FARI

Framework for Aerospace Research and Investigation. It is the top-level framework that organizes aerospace assessment evidence into defensible investigation and consolidated reports.

### Frame

The part of the workflow that defines client, mission context, scope, authorization, exclusions, assets, and claims before conclusions are made.

## **Acquire**

The phase where supplied material is preserved and normalized into evidence, facts, assertions, inferences, assumptions, contradictions, gaps, and sufficiency decisions.

## **Relate**

The phase where normalized material becomes findings, scenarios, SPARTA relationships, and reportable technical meaning.

## **Inform**

The phase where the report author chooses the conclusion, scenario disposition, required action, priority, and final reporting outputs.

## **Claim**

A precise statement of expected behavior that an investigation evaluates. A FARI conclusion always answers a claim within a declared scope boundary.

## **Evidence-backed fact**

A statement directly supported by preserved evidence without adding hidden interpretation.

## **Assertion**

A useful statement supplied by the technical reporter that has not been independently demonstrated by the report author.

## **Inference**

A report-author interpretation derived from facts, assertions, and surrounding context.

## **Assumption**

A condition treated as true for the current analysis even though it is not demonstrated by the available material.

## **Contradiction**

A meaningful conflict between observations, sources, or statements that affects the confidence or conclusion.

## **Gap**

Missing information that prevents a stronger or broader conclusion.

## **Technical sufficiency**

A qualitative decision about whether the evidence is enough to conclude the technical condition under test.

## **Reachability sufficiency**

A qualitative decision about whether the path to exploitation or exposure is supported within the present scope.

## **Mission sufficiency**

A qualitative decision about whether the mission or operational consequence is directly shown, partially supported, or still speculative.

## **Finding**

A normalized reportable condition derived from the investigation and connected to evidence, assets, claims, and optional framework mappings.

## **SPARTA**

The Space Attack Research and Tactic Analysis matrix. In FARI it is used as a behavior and countermeasure reference, especially for spacecraft-relevant techniques.

## **Conclusion**

The qualitative answer to the claim within the stated scope: Meets, Does Not Meet, Inconclusive, or Not Assessed.

## **Scenario disposition**

A separate qualitative statement about the broader attack path: Demonstrated, Plausible, Not Demonstrated, or Not Evaluated.

## **Scope boundary**

The exact limit of where the conclusion applies. It prevents readers from generalizing a narrow result beyond what the evidence supports.

## **Closed investigation**

An immutable investigation record with sufficient context, evidence basis, decision fields, and required action to stand as a final report artifact.

## **Closed assessment**

An immutable assessment whose gating investigations are closed and whose consolidated report is final for the declared scope.

## **Revision**

A named snapshot of the assessment state, such as v1 or v2, captured for traceability and difference review.

## **SBOM document**

A preserved inventory source file, such as CycloneDX, SPDX, package-lock JSON, or a dependency text list, stored as evidence for software composition tracking.

## **Inventory component**

A tracked software package or dependency record derived from an SBOM or dependency list and maintained over time with status and version changes.

## **Inventory event**

A timestamped traceability record attached to an inventory component, used to record vulnerability discovery, version movement, status changes, and fix verification.

## **Compliance scenario**

The qualitative way a compliance-oriented conversation is proceeding, such as evidence-backed alignment, partial alignment, compensating controls, or inconclusive scope.

## **Companion profile**

An overlay that maps FARI records to an external control baseline such as SPD-5, without changing the core FARI workflow or decision model.

## **Compliance posture**

The qualitative roll-up of a companion profile, such as Aligned, Partially Aligned, Gap Identified, Inconclusive, or Not Started.

## Appendix A: SPD-5 Companion Profile

### Companion profile for FARI v1.2.0

#### Purpose

This document defines a control-oriented overlay that can be used alongside FARI when an assessment also needs to support SPD-5-style compliance conversations.

FARI remains the core evidence and executive reporting framework.

The SPD-5 companion profile is:

- optional;
- qualitative;
- traceable back to FARI records;
- useful for executive readiness and gap-review conversations;
- not a certification, legal determination, or replacement for authority review.

#### Why a companion instead of changing FARI

FARI is built around claims, evidence normalization, scope boundaries, findings, SPARTA mappings, and executive conclusions.

SPD-5 is a principle set for space-system cybersecurity. It is better used as a control overlay than as the engine that drives every FARI decision.

That separation keeps both sides clean:

- FARI answers: *what was tested and what can be concluded?*
- the SPD-5 companion answers: *how does that evidence align with a known cybersecurity baseline?*

#### Source reference

- Official SPD-5 PDF (<https://www.transportation.gov/sites/dot.gov/files/2023-11/Memorandum%20on%20Space%20Policy%20Directive-5%E2%80%94Cybersecurity%20Principles%20for%20Space%20Systems.pdf>)
- DOT reference page (<https://www.transportation.gov/pnt/memorandum-space-policy-directive-5-cybersecurity-principles-space-systems>)

#### Recommended usage model

Use the companion profile at the **assessment** level, not as a replacement for individual investigations.

Each companion control should reference one or more existing FARI records, for example:

- investigation IDs;
- evidence IDs;
- asset IDs;

- SPARTA-linked findings;
- Attack Flow diagrams;
- SBOM documents;
- inventory component timelines.

## Compliance proceeding scenarios

These scenarios describe how a compliance-oriented assessment may proceed.

### 1. Evidence-backed alignment

Use when the relevant control exists and FARI has enough evidence to support that statement directly.

Typical pattern:

- control status mostly **Implemented**;
- evidence references are concrete;
- no material scope caveat remains.

### 2. Partial alignment

Use when the mission has meaningful control coverage, but some items are only partially implemented or still planned.

Typical pattern:

- a mix of **Implemented**, **Partially Implemented**, and **Planned**;
- gaps are known;
- the profile still helps prioritize work.

### 3. Compensating controls

Use when the expected control does not exist in its standard form, but another design choice reduces the same exposure.

Typical pattern:

- a direct control is absent;
- rationale explains why the alternative is acceptable;
- linked evidence shows the compensating behavior.

### 4. Inconclusive due to scope

Use when the current assessment cannot support a dependable compliance statement.

Typical pattern:

- limited environment or access;
- supplier black-box constraints;
- missing mission or operational evidence;

- many controls still Not Verified.

## 5. Supplier attestation pending

Use when third-party firmware, cloud services, or other external dependencies must provide additional evidence before the control can be accepted.

Typical pattern:

- vendor claim exists but local validation is missing;
- supply-chain or hosted-service controls remain open;
- the profile tracks what must still be obtained.

## 6. Continuous assurance

Use when the assessment becomes a living baseline and is revisited over time.

Typical pattern:

- SBOM imports change;
- monitoring coverage grows;
- fixes are retested;
- captured revisions document each state change.

## Control status model

Each control uses one of these values:

- Implemented
- Partially Implemented
- Planned
- Not Implemented
- Not Applicable
- Not Verified

Recommended interpretation:

- **Implemented**: supported by current evidence.
- **Partially Implemented**: some evidence exists, but not enough for a clean implementation statement.
- **Planned**: known remediation or project exists, but the control is not yet in force.
- **Not Implemented**: the control is absent or effectively not present.
- **Not Applicable**: the control does not belong to the declared scope.
- **Not Verified**: the control may exist, but the present assessment cannot support that statement.

## Companion posture model

The profile can roll up into a qualitative posture:

- Aligned
- Partially Aligned
- Gap Identified
- Inconclusive
- Not Started

Recommended interpretation:

- **Aligned:** applicable controls are implemented.
- **Partially Aligned:** some controls are implemented, but others are only partial or planned.
- **Gap Identified:** one or more applicable controls are clearly absent.
- **Inconclusive:** the profile is active, but evidence is still too incomplete for a stronger statement.
- **Not Started:** the profile has not yet moved beyond unverified controls.

## Control families

### Governance

- SPD5-G0V-01 Space system cybersecurity policy
- SPD5-G0V-02 Threat analysis performed
- SPD5-G0V-03 SPARTA threat model completed
- SPD5-G0V-04 Incident response procedures

### Ground Segment

- SPD5-GRD-01 MFA for operators
- SPD5-GRD-02 RBAC implemented
- SPD5-GRD-03 Command logging and auditability
- SPD5-GRD-04 SIEM integration
- SPD5-GRD-05 Network segmentation

### Space Segment

- SPD5-SPC-01 Authenticated telecommands
- SPD5-SPC-02 Encrypted telecommands
- SPD5-SPC-03 Firmware integrity validation
- SPD5-SPC-04 Secure boot
- SPD5-SPC-05 Positive control recovery
- SPD5-SPC-06 Safe mode documented



## Communications

- SPD5-COM-01 Replay protection
- SPD5-COM-02 Spoofing protection
- SPD5-COM-03 Cryptographic key management
- SPD5-COM-04 Credential rotation
- SPD5-COM-05 RF link protection

## Supply Chain

- SPD5-SUP-01 Software inventory (SBOM)
- SPD5-SUP-02 Third-party firmware validation
- SPD5-SUP-03 Change control
- SPD5-SUP-04 Signed updates

## Monitoring

- SPD5-MON-01 RF anomaly detection
- SPD5-MON-02 Telemetry monitoring
- SPD5-MON-03 Critical event alerting
- SPD5-MON-04 Post-incident forensic capability

## Manual workflow

1. Complete the normal FARI Frame.
2. Register assets, investigations, evidence, findings, SPARTA links, and any Attack Flow material.
3. If software composition matters, ingest SBOM material and inventory events.
4. Open the SPD-5 companion profile.
5. Select the current compliance proceeding scenario.
6. For each control, choose a qualitative status.
7. Add evidence references pointing back to existing FARI records.
8. Add notes for scope limits, compensating controls, or supplier dependencies.
9. Review the resulting posture as an executive signal, not as a legal certification.

## Web implementation guidance

The web interface should treat the SPD-5 companion as:

- an assessment-level module;
- optional for closure;
- revision-aware through the assessment snapshot system;
- exportable in JSON;

- readable in a future consolidated governance appendix if needed.

## Minimal worked example

Assessment:

- ASM-2026-0001
- SpaceCAN replay-resistance review

FARI evidence:

- INV-0001-001
- EVD-0001-001
- FND-0001-001
- AFB-0001-001

Companion interpretation:

- SPD5-COM-01 Replay protection -> Not Implemented
- SPD5-COM-02 Spoofing protection -> Partially Implemented
- SPD5-GOV-02 Threat analysis performed -> Implemented

Possible posture:

- Gap Identified

Possible scenario:

- Partial alignment

Reason:

- some governance work exists;
- communication-path defenses are incomplete;
- evidence supports a concrete remediation conversation.